

OWASP

Passive OSINT & External Attack Surface Assessment

Prepared by: Vasu Dadhaniya
Assessment Type: Passive OSINT Assessment
Target: owasp.org
Assessment Date: August 2026

01. Executive Summary
02. Scope & Rules of Engagement
03. Methodology
04. Domain & DNS Intelligence
05. Website Intelligence
06. Technology & Infrastructure
07. Public Digital Footprint
08. Findings & Risk Ratings
09. Recommendations
10. Evidence
11. Sources
12. Conclusion

Collection type: Passive DNS / WHOIS reconnaissance
Date collected: 13 August 2026
Registrar: GoDaddy.com, LLC
Registered: 21 September 2001
Expiration: 21 September 2031
Nameserver 1: fay.ns.cloudflare.com
Nameserver 2: west.ns.cloudflare.com
DNS Provider: Cloudflare
DNSSEC: Secure / Enabled

certificate transparency

1. owasp.org
2. www.owasp.org
3. www2.owasp.org
4. name-virt-host.owasp.org
5. contact.owasp.org
6. austin.owasp.org
7. prodsec.owasp.org
8. projectsummit.owasp.org
9. www.projectsummit.owasp.org
10. blt.owasp.org
11. pce.dev.owasp.org
12. cornucopia.owasp.org
13. genai.owasp.org
14. docs.owasp.org
15. cloud.owasp.org
16. support.owasp.org
17. support.docs.owasp.org
18. dsomm.owasp.org
19. ctf.owasp.org
20. copi.owasp.org
21. giving.owasp.org
22. ocms.owasp.org
23. nest.owasp.org
24. llm.owasp.org
25. secureflag.owasp.org

26. dev.owasp.org
27. wiki.owasp.org
28. new-wiki.owasp.org
29. cheatsheetseries.owasp.org
30. videos.owasp.org
31. mu.owasp.org
32. lists.owasp.org
33. www.lists.owasp.org
34. www.ocms.owasp.org
35. discourse.owasp.org
36. kerala.owasp.org
37. dsandbox.owasp.org
38. aghast.owasp.org
39. cheesemonkey.owasp.org
40. haroldtest.owasp.org
41. talk.owasp.org
42. tempcali.owasp.org
43. tsd.owasp.org
44. update-wiki.owasp.org
45. registration.owasp.org

DNS Record: A

Target: owasp.org

IPv4 Addresses:

- 104.20.44.163
- 172.66.157.115

TTL:

- 300 seconds

Network/Owner:

- Cloudflare Inc.
- AS13335

Security Assessment: Informational

Observation:

The root domain owasp.org resolves to two IPv4 addresses associated with Cloudflare infrastructure.

DNS Record: AAAA

Target: owasp.org

IPv6 Addresses:

- 2606:4700:10::ac42:9d73
- 2606:4700:10::6814:2ca3

TTL:

- 300 seconds

Network/Owner:

- Cloudflare Inc.

Security Assessment: Informational

Observation:

The root domain owasp.org resolves to two IPv6 addresses associated with Cloudflare infrastructure.

CNAME: No record observed

DNS Record: MX

Target: owasp.org

Mail Infrastructure:

- Priority 1: aspmx.1.google.com
- Priority 5: alt1.aspmx.1.google.com
- Priority 5: alt2.aspmx.1.google.com
- Priority 10: alt3.aspmx.1.google.com
- Priority 10: alt4.aspmx.1.google.com

Provider: Google LLC
Assessment: Informational
Observation:
The domain uses Google's mail infrastructure with multiple MX records providing primary and backup mail delivery.

DNS Record: TXT
Observed TXT Records:

SPF:
v=spf1 include:_spf.google.com
include:servers.mcsv.net
include:amazonses.com -all

Other TXT records observed:

- Multiple Google site verification records
- Atlassian domain verification record
- Microsoft domain verification record
- Additional verification token

SPF Assessment: Informational
SPF Observation:
The domain publishes an SPF record authorizing Google, Mailchimp-related infrastructure, and Amazon SES to send email on behalf of the domain.
SPF Policy: -all
Recommendation:
Periodically review authorized third-party email services and remove services that are no longer required.
Other TXT Assessment: Informational
Note:
Verification tokens are not reproduced in the final public report unless required.

6. DMARC RECORD

Target:
_dmarc.owasp.org

Record Type: TXT
TTL: 300 seconds
DMARC Version: DMARC1
DMARC Policy: quarantine
Aggregate Reporting: Configured
Reporting Address:
Configured
(Redacted from public report)

Assessment: Informational

Observation:

A DMARC record is published for the domain.

The policy is set to "quarantine", indicating that messages failing the applicable DMARC authentication checks may be treated as suspicious/quarantined by receiving mail systems.

The record also includes an aggregate reporting (RUA) configuration.

Recommendation:

Periodically review the DMARC policy and aggregate reporting configuration to ensure that the policy continues to match the organization's email-security requirements.

7. NS RECORD

Target:

owasp.org

Authoritative Nameservers:

1. fay.ns.cloudflare.com
IP: 108.162.192.115
2. west.ns.cloudflare.com
IP: 108.162.193.247

TTL: 86400 seconds

DNS Provider:

Cloudflare Inc.

AS13335

Assessment: Informational

Observation:

The domain uses two authoritative nameservers provided by Cloudflare.

The presence of multiple authoritative nameservers provides DNS service redundancy.

Note:

Nameserver information is publicly observable and does not by itself indicate a security vulnerability.

8. DNSSEC

Target: owasp.org

DNSSEC Status: Enabled

DNSKEY / DS / NSEC Status: Secure

Delegation Status: Secure

Observation:

DNSSEC is enabled for the owasp.org domain.
The DNSSEC authentication chain was observed as secure by DNSViz, with DS and DNSKEY records present.

Assessment:

Informational / Security Control Present

Security Impact:

DNSSEC provides cryptographic validation of DNS data and helps protect against unauthorized modification of DNS responses.

Conclusion:

No DNSSEC configuration issue was identified from the observed authentication-chain status.

Hostname: docs.owasp.org

A Record:

- 104.16.253.120
- 104.16.254.120

TTL:- 300 seconds

Observed Provider:

- Cloudflare Inc.
- AS13335

Observation:

The docs.owasp.org hostname resolves to two IPv4 addresses associated with Cloudflare infrastructure. The addresses differ from those observed for the root domain and llm.owasp.org.

Assessment: Informational

Note:

The observed IP addresses are Cloudflare edge infrastructure and should not be interpreted as the origin server addresses.

Hostname: docs.owasp.org

CNAME Record:- readthedocs.io.

TTL:- 300 seconds

Observation:

The docs.owasp.org hostname has a CNAME record pointing to readthedocs.io, indicating a publicly observable dependency on third-party documentation hosting infrastructure.

Assessment: Informational

Security Consideration:

Third-party DNS/hosting dependencies should be periodically reviewed to ensure that the referenced service and hostname remain authorized and required.

Evidence:

DNSChecker CNAME lookup for docs.owasp.org.

Hostname: cloud.owasp.org

A Record:- 157.245.12.71

TTL:- 300 seconds

Observed Provider:

- DigitalOcean LLC
- AS14061

Observation:

The cloud.owasp.org hostname resolves to an IPv4 address associated with DigitalOcean infrastructure. Unlike the root domain and llm.owasp.org, this hostname is not resolving to the same Cloudflare IPv4 addresses observed during this assessment.

Assessment: Informational

Security Note:

The observed IP identifies the hosting/network provider but does not by itself indicate the origin application's security posture or a vulnerability.

Hostname: cloud.owasp.org

CNAME Record:- No CNAME record observed

Hostname: support.owasp.org

A Records:

- 54.230.253.88
- 54.230.253.101
- 54.230.253.89
- 54.230.253.27

TTL:- 60 seconds

Observed Provider:

- Amazon.com Inc.
- AS16509

Observation:

The support.owasp.org hostname resolves to multiple IPv4 addresses associated with Amazon infrastructure.

The hostname uses a shorter TTL of 60 seconds compared with several other OWASP hostnames observed during the

assessment.

Assessment: Informational

Security Note:

The observed Amazon IP addresses and DNS configuration do not by themselves indicate a vulnerability.

Hostname: support.owasp.org

CNAME Record:

- support-owasp-org-bf6e704e-1ced-447d-a571-58c5c5e14ff5.saas.atlassian.com

TTL:- 300 seconds

Observation:

The support.owasp.org hostname has a CNAME record pointing to an Atlassian SaaS hostname, indicating a publicly observable dependency on Atlassian-hosted infrastructure.

The hostname also resolves to multiple IPv4 addresses associated with Amazon infrastructure.

Assessment: Informational

Security Note:

The presence of a third-party CNAME does not by itself indicate a vulnerability. Third-party DNS dependencies should be periodically reviewed to ensure that the referenced service remains authorized and required.

Hostname: ctf.owasp.org

A Records:

- 216.198.79.65

- 64.29.17.65

TTL:- 300 seconds

Observed Provider:

- Vercel Inc.

- AS16509

Observation:

The ctf.owasp.org hostname resolves to multiple IPv4 addresses associated with Vercel infrastructure.

Assessment: Informational

Security Note:

The observed Vercel IP addresses identify publicly observable hosting infrastructure and do not by themselves indicate a vulnerability.

Hostname: ctf.owasp.org

CNAME Record:

- 2e9be127c8b65fdd.vercel-dns-017.com.

TTL:- 300 seconds

Observation:

The ctf.owasp.org hostname has a CNAME record pointing to a Vercel DNS hostname, indicating a publicly observable dependency on Vercel-hosted infrastructure.

The hostname also resolves to multiple IPv4 addresses associated with Vercel infrastructure.

Assessment: Informational

Security Note:

The presence of a Vercel CNAME does not by itself indicate a vulnerability. It only documents the observed DNS and hosting relationship.

Hostname: projectsummit.owasp.org

A Record:- 103.169.142.0

TTL:- 3600 seconds

Observed Network/Owner:

- Canva

- AS209242

Observation:

The projectsummit.owasp.org hostname resolves to 103.169.142.0, which DNSChecker associates with Canva / AS209242.

Assessment: Informational

Security Note:

The observed IP ownership information identifies the network/organization associated with the address. It does not by itself establish that the underlying application is hosted directly by that organization or indicate a vulnerability.

Hostname: projectsummit.owasp.org

CNAME Record:

- No CNAME record observed

ID	Asset / Hostname	Observation
Evidence / Technical Detail		

Severity	Assessment
-----	-----
-----	-----
DNS-001	Multiple IPv4 addresses observed
Informational	Cloudflare infrastructure
DNS-002	Multiple IPv6 addresses observed
Informational	Cloudflare IPv6 infrastructure
DNS-003	No CNAME observed
Informational	Direct DNS configuration observed
DNS-004	Google mail infrastructure observed
Informational	Google mail infrastructure
DNS-005	SPF record published
Informational	SPF configured with -all
DNS-006	Multiple domain-verification TXT records observed
Informational	Google, Atlassian and Microsoft verification records
DNS-007	DMARC policy published
Informational	DMARC enforcement policy observed
DNS-008	Authoritative nameservers observed
Informational	Cloudflare authoritative DNS
DNS-009	DNSSEC enabled
Informational / Positive Control	DNSSEC authentication chain observed as secure
CT-001	Certificate Transparency enumeration identified multiple hostnames
Informational	Certificate-based attack-surface discovery
HOST-001	Cloudflare IPv4 infrastructure observed
Informational	Same Cloudflare edge IPs observed as root domain
HOST-002	Cloudflare IPv4 infrastructure observed

```

Informational | Different Cloudflare edge IPs
|
| **HOST-003** | `docs.owasp.org` | Third-party CNAME observed
| `readthedocs.io.`
| Informational | Read the Docs dependency
|
| **HOST-004** | `cloud.owasp.org` | DigitalOcean infrastructure
observed | `157.245.12.71` â€”
DigitalOcean, AS14061
Informational | Direct A record observed
|
| **HOST-005** | `cloud.owasp.org` | No CNAME observed
| CNAME lookup returned no record
| Informational | Direct A-record configuration
|
| **HOST-006** | `support.owasp.org` | Amazon infrastructure
observed | `54.230.253.88`, `.101`,
`.89`, `.27` â€” Amazon / AS16509
Informational | Multiple Amazon-associated IPv4
addresses
|
| **HOST-007** | `support.owasp.org` | Atlassian SaaS CNAME
observed | `support-owasp-org-
bf6e704e-1ced-447d-a571-58c5cce14ff5.saas.atlassian.com`
Informational | Atlassian SaaS dependency
|
| **HOST-008** | `ctf.owasp.org` | Vercel infrastructure
observed | `216.198.79.65`,
`64.29.17.65`
Informational | Vercel-associated infrastructure
|
| **HOST-009** | `ctf.owasp.org` | Vercel DNS CNAME observed
| `2e9be127c8b65fdd.vercel-dns-017.com.`
| Informational | Vercel DNS dependency
|
| **HOST-010** | `projectsummit.owasp.org` | Canva-associated
infrastructure observed | `103.169.142.0` â€”
Canva / AS209242
Informational | A record observed
|
| **HOST-011** | `projectsummit.owasp.org` | No CNAME observed
| CNAME lookup returned no record
| Informational | Direct A-record configuration
|

```

Executive Summary

A passive OSINT assessment of the owasp.org domain was performed using publicly available Certificate Transparency and DNS information.

The assessment identified multiple publicly observable

subdomains and infrastructure relationships involving Cloudflare, DigitalOcean, Amazon, Vercel, Read the Docs, Atlassian SaaS, and Canva-associated infrastructure.

Email-security controls including SPF and DMARC were observed on the root domain. DNSSEC was also observed with a Secure DNSSEC authentication and delegation status.

No vulnerability was established solely from the DNS and Certificate Transparency observations collected during this phase. The identified items primarily represent informational attack-surface and third-party infrastructure dependencies.

Severity	Count / Status
Critical	**0 identified**
High	**0 identified**
Medium	**0 identified**
Low	**0 confirmed**
Informational	**Multiple observations**
Positive Security Controls	**SPF, DMARC, DNSSEC**

=====

05. WEBSITE INTELLIGENCE

=====

5.1 Target Website

URL: <https://owasp.org>

Status: HTTP 200 OK

Page Title: OWASP Foundation, the Open Source Foundation for Application Security | OWASP Foundation

HTTP/HTTPS: HTTPS

Redirect Behavior: No redirect observed

5.2 HTTP RESPONSE HEADERS

Target: <https://owasp.org>

HTTP Status: 200 OK

Content-Type: text/html; charset=utf-8

Server: Cloudflare

Observed Security Headers:

1. Strict-Transport-Security
Value:
max-age=31536000; includeSubDomains

Status: Present
2. Content-Security-Policy
Status: Present

Observation:
CSP is configured with multiple allowed external domains and includes 'unsafe-inline' and 'unsafe-eval' in script-src.
3. Permissions-Policy
Value:
geolocation=(self)

Status: Present
4. Referrer-Policy
Value: same-origin

Status: Present
5. X-Content-Type-Options
Value: nosniff

Status: Present
6. X-Frame-Options
Value: SAMEORIGIN

Status: Present

Caching / Delivery Headers:

CF-Cache-Status: DYNAMIC
Cache-Control: max-age=600
Via: 1.1 varnish
x-cache: HIT
x-origin-cache: HIT
x-proxy-cache: HIT

Infrastructure Indicators:

Server: Cloudflare
x-github-edge-region: centralindia

x-served-by: cache-bom-vanm7210058-BOM

Assessment: Informational

Security Observation:

The website implements several commonly used HTTP security headers including HSTS, CSP, Referrer-Policy, X-Content-Type-Options and X-Frame-Options.

The CSP includes 'unsafe-inline' and 'unsafe-eval' within script-src. This may reduce CSP strictness and could be considered for future hardening where application functionality permits.

No confirmed vulnerability was established from the observed response headers alone.

5.3 ROBOTS.TXT

URL: <https://owasp.org/robots.txt>

Observed Content:

User-agent: *
Disallow: /membership-success/

Observation:

The robots.txt file contains a global crawler rule that disallows the /membership-success/ path.

Assessment: Informational

Security Assessment:

The observed robots.txt configuration does not by itself indicate a security vulnerability.

Note:

robots.txt is a crawler-control mechanism and should not be considered an access-control or security boundary.

5.4 SITEMAP

Sitemap Reference:

Not observed in robots.txt.

Assessment: Informational

5.5 TECHNOLOGY INDICATORS

Target: https://owasp.org

Method: Public HTML source inspection using curl.exe.

Command:

```
curl.exe -s https://owasp.org | findstr /i  
"generator poweredby wordpress jekyll hugo"
```

Observed Indicators:

- Jekyll-related comments/references

Evidence:

The HTML source contained references such as:
"jekyll menu stuff"

Observation:

Jekyll-related indicators were observed in the publicly accessible HTML source of owasp.org.

Assessment: Informational

Confidence: Medium

Note:

The observed source references indicate a Jekyll-related technology/component, but the evidence alone does not establish the complete underlying technology stack.

5.6 TLS / SSL CERTIFICATE

Target: https://owasp.org

Certificate Subject: CN=owasp.org

Organization: Not Part Of Certificate

Certificate Issuer: Google Trust Services

Issuer Common Name: WE1

Issued On: 08 July 2026 09:37:11 AM

Expires On: 06 October 2026 10:36:52 AM

Certificate Status: Valid at the time of observation

Certificate SHA-256 Fingerprint:

906957bef6e52048ef3320e7d2b112acc88d8fedc851c00adc9ca0ecebfaee1e

Public Key:

dd9164b7c84218625d271b8cd61bcc5dfa09cad696ee24d7f7343a9861417385

Assessment: Informational / Security Control Present

Observation:

The owasp.org website uses a valid HTTPS certificate issued by Google Trust Services. The certificate subject is owasp.org and the observed certificate validity period is from 08 July 2026 to 06 October 2026.

HSTS is also enabled on the website with the includeSubDomains directive.

No certificate validity issue was identified from the observed certificate information.

06. Technology & Infrastructure

6.1 HOSTING & CDN INFRASTRUCTURE

The assessment identified a distributed public infrastructure footprint across multiple hosting, CDN and SaaS providers.

Observed infrastructure includes:

- Cloudflare
- DigitalOcean
- Amazon
- Vercel
- Read the Docs
- Atlassian SaaS
- Canva-associated infrastructure

The observed provider relationships are based on public DNS resolution, CNAME records and HTTP response headers.

Assessment: Informational

Security Note:

The identification of third-party infrastructure does not by itself indicate a security vulnerability. It documents the publicly observable technology and service footprint.

6.3 WEB TECHNOLOGY INDICATORS

Observed Indicators:

- Jekyll-related references in publicly accessible HTML source
- Cloudflare identified through HTTP Server header
- Varnish-related caching indicator observed through the Via header

Assessment: Informational

Confidence: Medium

Note:

These indicators identify publicly observable technology/components but do not establish the complete underlying application stack.

6.4 THIRD-PARTY SERVICE DEPENDENCIES

Observed third-party relationships include:

1. docs.owasp.org
CNAME â†’ readthedocs.io
2. support.owasp.org
CNAME â†’ saas.atlassian.com
3. ctf.owasp.org
CNAME â†’ vercel-dns-017.com

These relationships indicate that selected OWASP public services rely on externally hosted or third-party infrastructure.

Assessment: Informational

Security Note:

Third-party dependencies should be periodically reviewed to ensure that DNS records remain associated with authorized and actively used services.

6.5 EMAIL INFRASTRUCTURE

MX infrastructure: Google mail infrastructure observed.

SPF:

v=spf1 include:_spf.google.com
include:servers.mcsv.net
include:amazonses.com -all

Observed authorized email-service dependencies:

- Google
- Mailchimp-related infrastructure
- Amazon SES

Assessment: Informational

Security Control: SPF is published with a hard-fail (-all) policy.

6.6 CERTIFICATE INFRASTRUCTURE

Primary observed certificate:

Subject: owasp.org

Issuer: Google Trust Services

Issuer Common Name: WE1

Validity: 08 July 2026 - 06 October 2026

Assessment: Informational / Security Control Present

Observation:

A valid HTTPS certificate was observed for the owasp.org domain during the assessment.

07. Public Digital Footprint

7.1 OFFICIAL WEB PRESENCE

Primary Domain: owasp.org

Primary Public Website: <https://owasp.org>

Observed Public Functions:

- OWASP Foundation information
- Projects
- Chapters
- Security documentation
- Community information
- Events and related resources

Assessment: Informational

Observation:

The primary OWASP domain acts as the central public web presence for the organization and provides access to projects, documentation, community resources and other publicly available information.

7.2 PUBLIC CODE & REPOSITORY FOOTPRINT

Primary Repository Platform: GitHub

Organization: OWASP

Public Repository Examples:

- OWASP/API-Security
- OWASP/DevGuide
- OWASP/Amass

Observation:

OWASP maintains a substantial publicly accessible software and documentation footprint through GitHub.

Public repositories may contain:

- Source code
- Documentation
- Configuration files
- Project metadata
- Issues
- Pull requests
- Release information

Assessment: Informational

Security Note:

Public availability of repositories is expected for open-source OWASP projects and does not by itself represent a security weakness.

7.3 PUBLIC PROJECTS & DOCUMENTATION

Observed Public Project Ecosystem:

- Security tools
- Security standards
- Security guides
- Application security documentation
- API security resources
- Developer guidance
- Attack-surface/security research resources

Example: OWASP API Security Project

Example: OWASP Developer Guide

Example: OWASP Amass Project

Observation:

The organization maintains a broad public technical content ecosystem consisting of software projects, documentation, security guidance and research-related resources.

Assessment: Informational

7.4 PUBLIC COMMUNITY & COMMUNICATION CHANNELS

Observed Public Communication Ecosystem:

- OWASP website
- GitHub
- Mailing lists

- Slack/community channels
- Social media
- Project-specific communication channels
- Chapter-specific community channels

Observation:

OWASP maintains a broad public communication ecosystem supporting projects, chapters, committees and the wider security community.

Assessment: Informational

Security Note:

Public communication channels are an expected part of OWASP's open-community model.

7.5 CERTIFICATE TRANSPARENCY & PUBLIC ASSET DISCOVERY

Source: Certificate Transparency data

Observed:

Multiple OWASP-related hostnames were identified through publicly available certificate information.

Purpose:

Certificate Transparency provides a passive method for identifying publicly issued certificates and associated hostnames.

Assessment: Informational

Security Note:

Certificate Transparency exposure is expected for public HTTPS services and does not itself indicate a vulnerability.

08. Findings & Risk Ratings

ID	Finding	Risk	Evidence
Impact			Status
-----	-----	-----	-----
-----	-----	-----	-----
F-001	Distributed third-party infrastructure providers	Infrastructure management complexity	Multiple DNS
Informational	Observed		
F-002	Third-party DNS/SaaS dependencies	Dependency/lifecycle risk	Atlassian, Vercel, Read the Docs
Informational	Observed		
F-003	CSP contains `unsafe-inline` / `unsafe-eval`		HTTP headers
Reduced CSP strictness		Low	Hardening

F-004 Public asset discovery via DNS/CT	DNS + CT records
Attack-surface visibility	Informational Observed
F-005 SPF/DMARC present	DNS records
Helps email security	Informational Positive control
F-006 DNSSEC secure	DNSViz
Helps DNS integrity	Informational Positive control

09. RECOMMENDATIONS

=====

9.1 Third-Party Infrastructure Management

Related Finding: F-001

Risk: Informational

Recommendation:

Maintain a centralized inventory of publicly exposed domains, subdomains, IP addresses, hosting providers, CDN services and third-party infrastructure.

Periodically verify whether each identified service is still active, authorized and required.

Objective:

Reduce unnecessary public attack-surface exposure and improve infrastructure visibility.

9.2 Third-Party DNS and SaaS Dependencies

Related Finding: F-002

Risk: Informational

Recommendation:

Regularly review CNAME and other DNS records pointing to third-party services such as hosting platforms, SaaS providers and documentation platforms.

Remove obsolete DNS records when associated services are permanently decommissioned.

Objective:

Reduce risks associated with stale or unnecessary third-party dependencies.

9.3 Content Security Policy Hardening

Related Finding: F-003

Risk: Low / Hardening Observation

Recommendation:

Where application functionality permits, evaluate removing 'unsafe-inline' and 'unsafe-eval' from the Content-Security-Policy script-src directive.

Consider using nonce- or hash-based controls for required inline scripts and minimize unnecessary third-party script sources.

Objective:

Improve the restrictive nature of the Content Security Policy and strengthen client-side security controls.

Note:

This is a security-hardening recommendation and not a confirmed XSS vulnerability.

9.4 Public Asset Monitoring

Related Finding: F-004

Risk: Informational

Recommendation:

Perform periodic reviews of publicly discoverable subdomains, DNS records, IP addresses and Certificate Transparency records.

Identify and remove obsolete or unauthorized public assets where applicable.

Objective:

Maintain an accurate external attack-surface inventory.

9.5 Email Security Controls

Related Finding: F-005

Risk: Informational / Positive Security Control

Recommendation:

Continue maintaining SPF and DMARC configurations.

Periodically review authorized email-sending services and remove obsolete SPF mechanisms when no longer required.

Monitor DMARC reporting where available.

Objective:

Maintain protection against unauthorized email sending and domain spoofing.

9.6 DNSSEC Maintenance

Related Finding: F-006

Risk: Informational / Positive Security Control

Recommendation:

Continue monitoring DNSSEC configuration and validate the DNSSEC chain after DNS-provider or nameserver changes.

Objective:

Maintain DNS integrity and prevent accidental DNSSEC configuration failures.

9.7 Overall Recommendation

Maintain a periodic external attack-surface review covering DNS, subdomains, public IP addresses, third-party services, certificates, web technologies and publicly accessible organizational resources.

The review should identify newly introduced, obsolete or unexpected public-facing assets and ensure that they remain authorized and appropriately managed.

10. EVIDENCE

=====

10.1 Evidence Management

All findings and observations documented in this assessment are supported by evidence collected through passive DNS analysis, publicly accessible website inspection, HTTP response analysis, TLS certificate inspection and publicly available digital-footprint sources.

Evidence has been assigned unique identifiers for traceability between findings and supporting material.

10.2 Evidence Register

E-001

Evidence Type: DNS Resolution

Target: owasp.org

Description:

DNS records for the primary OWASP domain were collected to identify publicly observable IP addresses and DNS infrastructure.

Related Finding: F-001 / F-004

Evidence File: 01-owasp-dns-records.png

E-002

Evidence Type: DNS / CNAME

Target: docs.owasp.org

Description:

CNAME relationship to Read the Docs infrastructure was observed.

Related Finding: F-002

Evidence File: 02-docs-cname.png

E-003

Evidence Type: DNS / CNAME

Target: support.owasp.org

Description:

CNAME relationship to Atlassian SaaS infrastructure was observed.

Related Finding: F-002

Evidence File: 03-support-cname.png

E-004

Evidence Type: DNS / CNAME

Target: ctf.owasp.org

Description:

CNAME relationship to Vercel-associated infrastructure was observed.

Related Finding: F-002

Evidence File: 04-ctf-cname.png

E-005

Evidence Type: DNS / A Record

Target: projectsummit.owasp.org

Description:

A record resolving to 103.169.142.0 was observed. The DNS lookup identified Canva / AS209242 as the associated network information.

Related Finding: F-001

Evidence File: 05-projectsummit-a-record.png

E-006

Evidence Type: DNS / TXT

Target: owasp.org

Description:

Multiple TXT records were observed, including Google site verification, Microsoft verification, Atlassian domain verification and SPF-related information.

Related Finding: F-005

Evidence File: 06-owasp-txt-records.png

E-007

Evidence Type: HTTP Response Headers

Target: https://owasp.org

Description:

HTTP response headers were collected using curl. The response returned HTTP 200 OK and included security-related headers such as:

- Strict-Transport-Security
- Content-Security-Policy
- X-Content-Type-Options
- X-Frame-Options
- Referrer-Policy
- Permissions-Policy

Related Finding: F-003

Evidence File: 07-owasp-http-headers.png

E-008

Evidence Type: Content Security Policy

Target: https://owasp.org

Description:

The observed Content-Security-Policy contains 'unsafe-inline' and 'unsafe-eval' within the script-src directive.

Related Finding: F-003

Evidence File: 08-csp-unsafe-inline-eval.png

E-009

Evidence Type: robots.txt

Target: https://owasp.org/robots.txt

Description: The robots.txt file contains:

User-agent: *

Disallow: /membership-success/

Related Finding: Informational

Evidence File: 09-owasp-robots-txt.png

E-010

Evidence Type: Technology Indicator

Target: https://owasp.org

Description:

Jekyll-related references were observed within the publicly accessible HTML source.

Example: "jekyll menu stuff"

Related Finding: Informational

Evidence File: 10-jekyll-indicator.png

E-011

Evidence Type: TLS / SSL Certificate

Target: https://owasp.org

Description: A valid certificate was observed for owasp.org.

Subject: CN=owasp.org

Issuer: Google Trust Services

Issuer CN: WE1

Issued: 08 July 2026

Expires: 06 October 2026

Related Finding: Informational / Positive Security Control

Evidence File: 11-owasp-tls-certificate.png

E-012

Evidence Type: DNSSEC

Target: owasp.org

Description:

DNSSEC status was assessed using DNSViz and the observed DNSSEC authentication chain was reported as secure.

Related Finding: F-006

Evidence File: 12-owasp-dnssec.png

E-013

Evidence Type: Public Digital Footprint

Target: OWASP public ecosystem

Description:

Publicly accessible OWASP repositories, projects, documentation and community resources were identified.

Related Finding: F-004

Evidence File: 13-public-digital-footprint.png

11. SOURCES

11.1 Primary Target

1. OWASP Official Website
<https://owasp.org/>

Purpose:

Primary website inspection, HTTP response analysis, robots.txt inspection and public website information.

11.2 DNS & Domain Intelligence

2. DNSChecker
<https://dnschecker.org/>

Purpose:

DNS record lookup, A, AAAA, CNAME, MX, TXT and related DNS information.

3. DNSViz
<https://dnsviz.net/>

Purpose:

DNSSEC analysis and DNS delegation/validation visualization.

11.3 TLS / SSL Certificate

4. Browser Certificate Viewer / TLS Certificate

Source:

<https://owasp.org/>

Purpose:

Certificate subject, issuer and validity information.

11.4 Public Digital Footprint

5. OWASP GitHub Organization

<https://github.com/OWASP>

Purpose:

Public repository and open-source project footprint assessment.

6. OWASP Projects

<https://owasp.org/projects/>

Purpose:

Public project ecosystem and project information.

7. OWASP Site Documentation

<https://owasp.org/site-documentation/>

Purpose:

Public documentation and GitHub/project ecosystem verification.

11.5 Public Communication / Community Sources

8. OWASP Social Media Policy

<https://policy.owasp.org/operational/social-media/>

Purpose:

Public social-media and communication ecosystem information.

9. OWASP Mailing List Policy

<https://policy.owasp.org/operational/mailing-list.html>

Purpose:

Public mailing-list and communication-channel information.

11.6 Command-Line Collection

10. Windows PowerShell / curl.exe

Commands used included:

`curl.exe -s https://owasp.org`

```
curl.exe -s https://owasp.org | findstr /i  
"generator poweredby wordpress jekyll hugo"
```

```
curl.exe -vI https://owasp.org
```

Purpose:

Public HTML inspection and HTTP/TLS response
header collection.

12. CONCLUSION

=====

The passive OSINT assessment of the OWASP public internet footprint identified a distributed ecosystem of domains, subdomains, cloud infrastructure, CDN services, SaaS dependencies, public repositories, documentation and community resources.

The assessment identified publicly observable infrastructure associated with multiple providers, including Cloudflare, DigitalOcean, Amazon, Vercel, Read the Docs, Atlassian and Canva-associated infrastructure.

Website analysis confirmed HTTPS availability, security-related HTTP response headers, HSTS, Content Security Policy, X-Frame-Options, X-Content-Type-Options and other security controls.

A Jekyll-related indicator was also observed in the public HTML source.

The public digital-footprint assessment identified OWASP's open-source GitHub ecosystem, public security projects, documentation and community resources.

No confirmed Critical, High or Medium severity vulnerability was identified through the passive OSINT assessment performed.

One Low-severity security hardening observation was identified regarding the use of 'unsafe-inline' and 'unsafe-eval' within the observed Content Security Policy. This observation does not constitute a confirmed XSS vulnerability.

Additional observations were classified as Informational, including third-party infrastructure dependencies and publicly discoverable assets.

Positive security controls were also observed, including SPF, DMARC, DNSSEC, HTTPS and HSTS.

Overall, the assessment provides a structured view of the publicly observable OWASP attack surface and identifies areas that can be monitored or hardened

without asserting vulnerabilities that were not verified during the assessment.